

Windows Defender Firewall and Malware Prevention

Name: Chidozie David Okechukwu

Course: Cybersecurity

Date: April 6, 2026

Introduction

In a modern fintech organisation that handles sensitive customer data, daily network security is crucial for the Confidentiality, Integrity and Availability of customers data

1.1 Windows Defender Firewall Protection (If Implemented)

To prevent the malware from communicating with an external command-and-control(C2) server the firewall will implement outbound rules.How the firewall handles this:

Identification of the connection attempt

After the malware has been executed it attempts to connect with an external server. Before the data leaves the windows firewall intercepts the request.

Rule comparison

The firewall checks its list of outbound rules and looks for specific program (the malicious .exe program or the process hijacked), the remote ports (eg. ports 80, 443, or any non-standard ports for data exfiltration) and the destination IP.

The execution of the “Block”

If Chidi has configured a “Block by Default” outbound rule the firewall will block any connection that has not been whitelisted.

Why outbound policy

This requires an outbound rule because the traffic is originating from inside the company's network and attempting to reach an external network (the internet).

Direction: The inbound rule controls the traffic coming into the computer. The outbound rule controls the traffic going out of the computer.

Prevention of exfiltration: The primary goal here is to stop data from moving out of the computer. Since the malware is now inside the company's workstation it is no longer an inbound threat to that specific computer rather it is an internal actor trying to send data out.

1.2 The attacker: Scanning for open ports and vulnerabilities

Intrusion Prevention System(IPS)

Chidi should have an edge firewall (like OPNsense, Fortnet, Sophos) to detect port scanning behaviour and automatically drop any connection from the attacker IP before even reaching the other 50 workstations.

1.3 The staff: Unsecure network connectivity

The company's networking team should configure all company systems to connect only to the company's network. There are three ways of achieving this:

1. **Using the Netsh Command Wi-Fi Whitelisting:** This effectively hides all other networks from the user's view.
2. **Using Windows Defender Firewall (network isolation):** Restricts traffic based on the Network Profile (Domain, Private, or Public).
3. **Group Policy Object (GPO):** A Centralized management from a Domain Controller.

1.4 Remediation and Incident Response

Once the Windows Defender Firewall has successfully blocked the malware's outbound connection, the SOC team must take the following steps to clean the environment:

Host Isolation: The affected workstation should be immediately disconnected from the network (either physically or via a "Network Isolate" command in a security tool) to prevent the malware from spreading laterally to the other 49 computers.

Malware Removal & Re-Imaging: Simply deleting the attachment is often not enough. The IT team should run a full EDR (Endpoint Detection and Response) scan. In a high-security fintech environment, the safest remediation is to **wipe the hard drive and re-install Windows 11 Pro** from a known-clean backup.

Credential Reset: Because the malware may have captured keystrokes before it was blocked, the staff member must change all their passwords (Email, Banking, and Internal VPN) from a different, uninfected device.

Root Cause Analysis (RCA): Chidozie should investigate how the email bypassed the initial spam filters. This might lead to updating the **Email Security Gateway** or blacklisting the sender's domain company-wide.

Conclusion

In a standard windows environment the default setting is to allow any outbound traffic that does not match a specific block rule. Chidi would have implemented one of this:

Strict outbound filtering: Changing the default outbound rule to “Block” and only allowing essential applications (chrome, edge etc) to communicate externally.

Application-Aware-Filtering: To block malicious exe from using port 80, 443 or any non-standard port for data exfiltration).

Chidi will do this by implementing an outbound rule that says “Allow chrome, edge and outlook to use port 443 block any malicious exe from using port 443”.

App based blocking: If the malware is a known threat then an outbound rule should be set to block that specific exe or the IP of the attacker.

Proactive Defense: An annual penetration testing should be conducted, a monthly vulnerability assessment(*the industry standard for fintech companies*) and an annual phishing awareness training.